ТУСУР
TUSUR UNIVERSITY

Безопасность коммуникаций

Управление информационной безопасностью. Лекция 2.9

13 Безопасность коммуникаций

Раздел включает в себя 2 категорий и 7 мер обеспечения информационной безопасности:

13.1 Менеджмент информационной безопасности сетей
Цель: Обеспечить защиту информации в сетях и в образующих их средствах обработки информации.

- 13.1.1 Меры обеспечения информационной безопасности сетей
- 13.1.2 Безопасность сетевых сервисов
- 13.1.3 Разделение в сетях

13.2 Передача информации
Цель: Поддерживать безопасность информации, передаваемой как внутри организации, так и при обмене с любым внешним объектом и субъектом.

- 13.2.1 Политики и процедуры передачи информации
- 13.2.2 Соглашения о передаче информации
- 13.2.3 Электронный обмен сообщениями
- 13.2.4 Соглашения о конфиденциальности или неразглашении

Меры обеспечения информационной безопасности сетей

ТУСУР
TUSUR UNIVERSITY

Сети должны управляться и контролироваться для обеспечения защиты информации в системах и приложениях.

Должны быть реализованы меры для обеспечения безопасности информации в сетях и защиты подключенных сервисов от несанкционированного доступа. В частности, следует учитывать следующее:

a) должны быть установлены обязанности и процедуры для управления сетевым оборудованием;
b) там, где это применимо, обязанности по эксплуатации сетей должны быть отделены от обязанностей по эксплуатации компьютеров;
c) должны быть установлены специальные меры обеспечения ИБ для защиты конфиденциальности и целостности данных, передаваемых по сетям общего пользования или беспроводным сетям, и для защиты подключенных систем и приложений; могут потребоваться специальные меры для обеспечения доступности сетевых сервисов и подключенных компьютеров;
d) должна вестись соответствующая регистрация и мониторинг с целью фиксации и обнаружения действий, которые могут повлиять на ИБ или имеют отношение к ней;
e) действия по управлению должны быть тесно координированы как для того, чтобы оптимизировать обслуживание организации, так и для обеспечения того, чтобы меры обеспечения безопасности применялись согласованно в рамках всей инфраструктуры обработки информации;
f) системы в сетях должны проходить процедуру аутентификации;
g) подключение систем к сети должно быть ограничено.

Безопасность сетевых сервисов

Механизмы обеспечения безопасности, уровни обслуживания и требования к управлению для всех сетевых сервисов должны быть идентифицированы и включены в соглашения по сетевым сервисам независимо от того, будут ли они обеспечиваться силами организации или осуществляться с использованием аутсорсинга.

Следует определить и регулярно подвергать мониторингу способность поставщика сетевых сервисов безопасно управлять сервисами, определенными договором, а право проведения аудита должно быть согласовано.

Должны быть определены меры по обеспечению безопасности, необходимые для конкретных сервисов, такие как функции безопасности, уровни обслуживания и требования к управлению. Организация должна гарантировать, что поставщики сетевых сервисов реализуют эти меры.

Безопасность сетевых сервисов

Сетевые сервисы включают в себя обеспечение соединений, сервисы частных сетей и сетей с расширенными возможностями, а также решения, касающиеся управления безопасностью сети, такие как межсетевые экраны и системы обнаружения вторжений. Эти сервисы могут варьироваться в диапазоне от простого предоставления неуправляемой полосы пропускания до сложных решений с дополнительными услугами.

Функциями безопасности сетевых сервисов могут быть:

a) технологии, применяемые для обеспечения безопасности сетевых сервисов, например аутентификация, шифрование и контроль сетевых подключений;
b) технические параметры, необходимые для безопасного подключения к сетевым сервисам в соответствии с правилами безопасности сетевых соединений;
c) процедуры использования сетевых сервисов, применяемые с целью ограничения доступа к сетевым сервисам или приложениям, где это необходимо.

Разделение в сетях

Группы информационных сервисов, пользователей и информационных систем в сети должны быть разделены.

Одним из методов управления безопасностью больших сетей является разделение их на отдельные сетевые домены. Домены могут быть выбраны на основе уровней доверия (например, общедоступный домен, домен рабочих станций, домен сервера), на основе организационных подразделений (например, кадры, финансы, маркетинг) или на основе некоторой комбинации признаков (например, домен сервера, соединенный с несколькими организационными подразделениями). Разделение может быть выполнено физическим разделением на разные сети либо логическим (например, виртуальные частные сети).

Границы каждого домена должны быть четко определены. Доступ между сетевыми доменами может быть разрешен, но должен контролироваться на границе с использованием шлюза (например, межсетевого экрана, фильтрующего маршрутизатора). Критерии разделения сетей на домены и разрешение доступа через шлюзы должны основываться на оценке требований по безопасности каждого домена. Оценка должна проводиться в соответствии с политикой управления доступом и требованиями к доступу, в соответствии с ценностью и категорией обрабатываемой информации, а также с учетом относительной стоимости и влияния применяемой технологии шлюза на производительность.

Разделение в сетях

Беспроводные сети требуют особого подхода в силу того, что их границы не являются достаточно определенными. В отношении чувствительных сегментов следует принять подход, при котором все запросы на беспроводной доступ следует рассматривать как внешние и отделять их от запросов внутренних сетей до тех пор, пока запрос не пройдет шлюз и не будет разрешен доступ к внутренним системам в соответствии с политикой обеспечения ИБ сетей.

Технологии аутентификации, шифрования и управления доступом к сети на уровне пользователя, основанные на современных стандартах беспроводных сетей, при должной реализации могут быть достаточными для прямого подключения к внутренней сети организации.

Сети часто выходят за границы организации, поскольку создаются деловые отношения, которые требуют объединения или совместного использования сетевого оборудования и устройств обработки информации. Такие действия могут увеличивать риск неавторизованного доступа к информационным системам организации, использующим сеть, причем в отношении некоторых из этих систем может потребоваться защита от пользователей другой сети в силу их чувствительности или критичности.

Политики и процедуры передачи информации

Должны существовать формализованные политики и процедуры передачи информации, а также соответствующие меры, обеспечивающие безопасность информации, передаваемой с использованием всех видов средств связи.

Процедуры и меры обеспечения ИБ, которым необходимо следовать при использовании средств связи для передачи информации, должны учитывать следующее:

a) процедуры, предназначенные для защиты передаваемой информации от перехвата, копирования, модификации, перенаправления и уничтожения;
b) процедуры обнаружения и защиты от вредоносных программ, которые могут передаваться с использованием электронных средств связи;
c) процедуры для защиты информации ограниченного доступа в электронном виде, передаваемой в форме вложения;
d) политику или руководства, определяющие допустимое использование средств связи;
e) обязанности персонала, внешних сторон и любых иных пользователей не предпринимать действий, ставящих под угрозу организацию, например посредством клеветы, домогательств, неправомерного представления себя от лица организации, рассылки писем по цепочке, неавторизованных закупок и т.д.;
f) использование криптографических методов, например для защиты конфиденциальности, целостности и аутентичности информации;

Политики и процедуры передачи информации

g) руководства по срокам хранения и утилизации всей деловой переписки, включая сообщения, соответствующие национальному и местному законодательству и нормативным документам;
h) меры обеспечения ИБ и ограничения, связанные с использованием средств связи, например автоматическая пересылка электронной почты на внешние почтовые адреса;
i) рекомендации персоналу предпринимать меры предосторожности во избежание раскрытия конфиденциальной информации;
j) не оставлять сообщения, содержащие конфиденциальную информацию на автоответчиках, так как они могут быть прослушаны неавторизованными лицами, сохранены в системах общего пользования или некорректно записаны в результате ошибочного набора номера;
k) консультирование персонала о проблемах, связанных с использованием факсов и соответствующих услуг, а именно:
   1) неавторизованный доступ к встроенным хранилищам сообщений для извлечения сообщений;
   2) преднамеренное или случайное программирование машин на отправку сообщений на определенные номера;
   3) отсылка документов и сообщений на неверный номер в результате ошибочного набора либо вызова сохраненного неверного номера.

Политики и процедуры передачи информации

Персоналу следует напоминать, что не следует вести конфиденциальные разговоры в общественных местах или по небезопасным каналам связи, в открытых офисах и переговорных.

Услуги по передаче информации должны соответствовать всем релевантным требованиям законодательства.

Передача информации может осуществляться с использованием ряда различных типов средств связи, включая электронную почту, голосовую и факсимильную связь, а также видео.

Передача программного обеспечения может осуществляться различными способами, включая загрузку из Интернета и приобретение у поставщиков, продающих готовые продукты.

Следует учитывать юридические последствия, влияние на бизнес и безопасность, связанные с обменом электронными данными, электронной торговлей и электронной связью, а также требования к мерам обеспечения ИБ.

Соглашения о передаче информации

Безопасная передача деловой информации между организацией и внешними сторонами должна быть определена соглашениями.

Соглашения по передаче информации должны включать в себя следующее:

a) обязанности руководства по контролю и уведомлению о передаче, отправке и получении;
b) процедуры для обеспечения прослеживаемости и неотказуемости;
c) минимальные требования технических стандартов для упаковки и передачи;
d) соглашения условного депонирования (эскроу);
e) стандарты по идентификации курьеров;
f) ответственность и обязательства в случае инцидентов ИБ, таких как потеря данных;
g) использование согласованной системы маркирования для информации ограниченного доступа, гарантирующей, что значение этой маркировки будет сразу же понято и что информация будет соответствующим образом защищена;
h) технические стандарты для записи и чтения информации и программного обеспечения;
i) любые специальные меры обеспечения ИБ, которые требуются для защиты чувствительных элементов, например криптография;
j) поддержание цепочки сохранности информации в процессе передачи;
k) приемлемые уровни управления доступом.

Соглашения о передаче информации

Должны быть разработаны и поддерживаться политики, процедуры и стандарты по защите информации и физических носителей в процессе передачи, на них следует ссылаться в соглашениях о передаче.

Часть любого соглашения, посвященного ИБ, должна отражать степень доступности деловой информации.

Соглашения могут быть в электронном или бумажном виде и могут иметь форму официальных договоров. Конкретные механизмы, используемые для передачи конфиденциальной информации, должны быть согласованы для всех организаций и типов соглашений.

Электронный обмен сообщениями

Следует обеспечивать соответствующую защиту информации при электронном обмене сообщениями.

Соображения по обеспечению ИБ электронных сообщений должны включать следующее:

a) защиту сообщений от несанкционированного доступа, изменения или отказа в обслуживании в соответствии с системой категорирования, принятой в организации;
b) обеспечение правильной адресации и передачи сообщения;
c) надежность и доступность сервиса;
d) правовые аспекты, например требования к электронным подписям;
e) получение одобрения до использования внешних общедоступных сервисов, например сервисов мгновенных сообщений, социальных сетей или сервисов обмена файлами;
f) более высокий уровень аутентификации при контроле доступа из общедоступных сетей.

Существует много типов электронных сообщений, таких как электронная почта, обмен электронными данными и социальные сети, которые играют важную роль в деловых отношениях.

Соглашения о конфиденциальности или неразглашении

ТУСУР
TUSUR UNIVERSITY

Требования в отношении соглашений о конфиденциальности или неразглашении, отражающие потребности организации в обеспечении защиты информации, должны быть идентифицированы, документально оформлены и регулярно пересматриваться.

В соглашениях о конфиденциальности или неразглашении должно содержаться требование по защите конфиденциальной информации, выраженное юридическими терминами, имеющими исковую силу.

Соглашения о конфиденциальности или неразглашении применимы к внешним сторонам или работникам организации. Содержание соглашения должно определяться с учетом типа другой стороны, предоставляемого доступа или обработки конфиденциальной информации.

Соглашения о конфиденциальности или неразглашении

ТУСУР
TUSUR UNIVERSITY

При определении требований к соглашениям о конфиденциальности или неразглашении необходимо учитывать следующее:

a) определение информации, подлежащей защите (например, конфиденциальной информации);
b) ожидаемый срок действия соглашения, включая случаи, когда конфиденциальность должна обеспечиваться в течение неопределенного времени;
c) действия, необходимые при расторжении соглашения;
d) обязанности и действия лиц, подписавших соглашение, во избежание несанкционированного раскрытия информации;
e) право собственности на информацию, коммерческую тайну и интеллектуальную собственность и то, как это связано с защитой конфиденциальной информации;
f) разрешенное использование конфиденциальной информации и права лиц, подписавших соглашение, в отношении использования информации;
g) право на аудит и мониторинг деятельности, связанной с конфиденциальной информацией;
h) процесс уведомления и сообщения о несанкционированном раскрытии или утечке конфиденциальной информации;
i) условия, при которых информация должна быть возвращена или уничтожена в случае прекращения действия соглашения;
j) предполагаемые действия, которые должны быть предприняты в случае нарушения соглашения.

Соглашения о конфиденциальности или неразглашении

ТУСУР
TUSUR UNIVERSITY

Исходя из требований ИБ организации, может потребоваться добавление других элементов в соглашения о конфиденциальности или неразглашении.

Соглашения о конфиденциальности и неразглашении должны соответствовать всем применимым законам и нормативным документам, под юрисдикцию которых они подпадают.

Требования соглашений о конфиденциальности и неразглашении следует пересматривать периодически и в тех случаях, когда происходят изменения, затрагивающие эти требования.

Соглашения о конфиденциальности и неразглашении защищают информацию организации, а также надежным и правомочным образом информируют лиц, подписавших соглашение, об их ответственности за защиту, использование и разглашение информации.

В зависимости от различных обстоятельств организации могут потребоваться различные формы соглашений о конфиденциальности или неразглашении.

Рассмотренные вопросы

Безопасность коммуникаций:

- Меры обеспечения информационной безопасности сетей. Разделение в сетях.
- Политики и процедуры передачи информации, соглашения о передаче информации
- Соглашения о конфиденциальности или неразглашении

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!